

Лекция 05



Анализ, исправление и проверка дефектов безопасности

**Что нужно сделать, чтобы утверждение
«дефект исправлен» стало доказанным?**

Факультет компьютерных наук

Бакалаврская образовательная программа 09.03.04 «Программная инженерия» · 3 курс

Дисциплина «Разработка безопасного программного обеспечения» · 2026/2027 учебный год



После лекции вы сможете

2 / 39

- 1** зафиксировать воспроизводимый сценарий и отличить симптом от причины
- 2** связать исправляющее изменение с установленной причиной и выбрать необходимые проверки
- 3** собрать прослеживаемую цепочку доказанного исправления для конкретной версии продукта

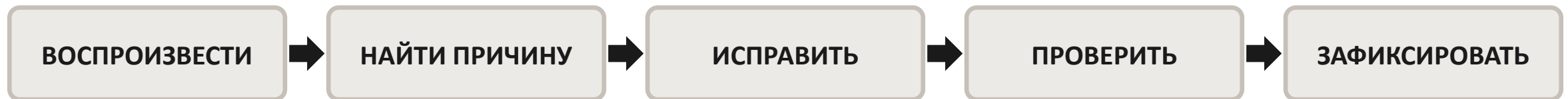
Материал лекции 05 не входит в ДЗ-1; ДЗ-1 охватывает материал лекций 01-04



Секция 1

Цена недоказанного исправления

Изменение кода ещё не означает, что дефект устранён





Что позволяет сказать «исправлено»?

4 / 39

- | | | |
|----------|--|----------------------------------|
| А | код изменён | ФАКТ, НО НЕДОСТАТОЧНО ДЛЯ ВЫВОДА |
| Б | проблема один раз не проявилась | ФАКТ, НО НЕДОСТАТОЧНО ДЛЯ ВЫВОДА |
| В | штатная функция работает | ФАКТ, НО НЕДОСТАТОЧНО ДЛЯ ВЫВОДА |
| Г | исходный нежелательный сценарий не проходит на определённой версии;
полезное и затронутое смежное поведение проверено | |

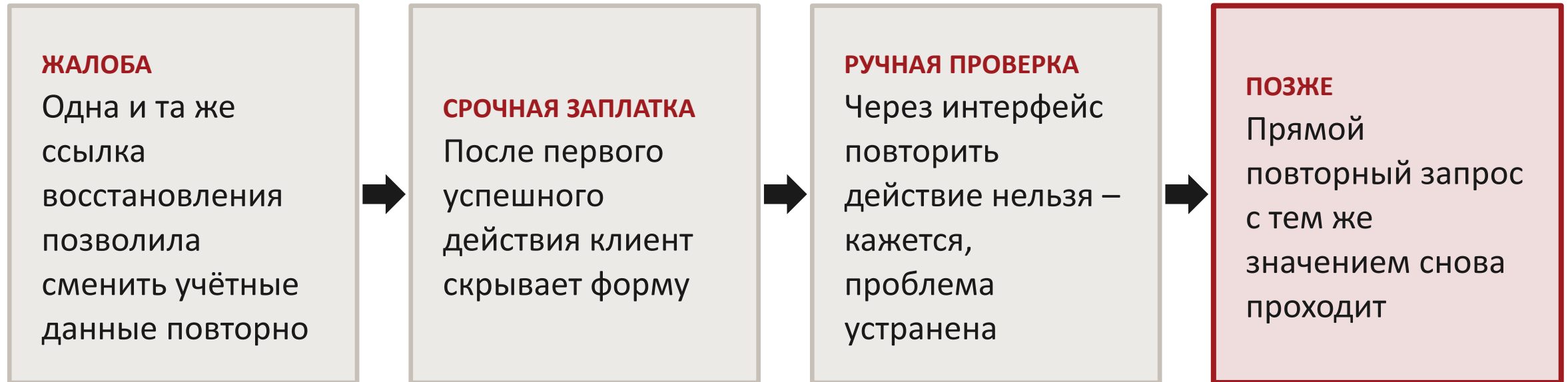
**Г – наиболее доказательное утверждение:
только его можно проверить и предъявить**



Жалоба, заплатка и возврат проблемы

5 / 39

Сервис восстановления доступа: одноразовая ссылка



Что именно мы исправили – и что вообще было причиной?



Что такое дефект безопасности

6 / 39

Дефект безопасности

– недостаток требований, проектирования, кода или конфигурации, из-за которого защитное свойство не обеспечивается должным образом. Анализ устанавливает проявление, причину и условия, в которых недостаток может привести к нарушению безопасности.

Где может находиться недостаток

требования

проектирование

код

конфигурация

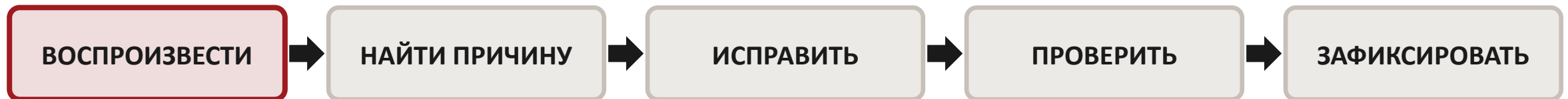
**Дефект безопасности не сводится
к ошибке программного кода**



Секция 2

Воспроизводимость прежде всего

Пока нет устойчивого сценария, сравнить состояние до и после невозможно





Жалоба – ещё не воспроизводимый сценарий

8 / 39

ЖАЛОБА

«Та же ссылка иногда срабатывает повторно»

ЧТО АНАЛИЗИРУЕМ

версию с клиентской заплаткой; повтор отправляется прямым запросом

Воспроизводимый сценарий

ПРЕДУСЛОВИЯ

?

ДЕЙСТВИЯ

?

НАБЛЮДАЕМЫЙ РЕЗУЛЬТАТ

?

ОЖИДАЕМЫЙ РЕЗУЛЬТАТ

?

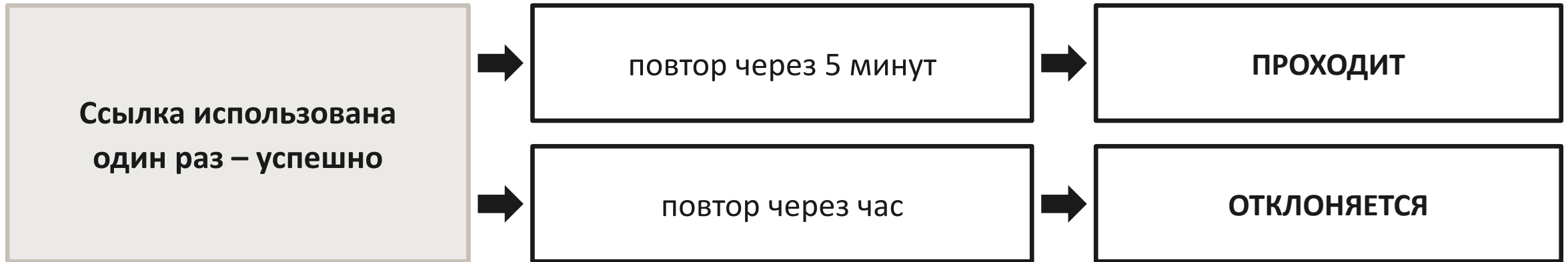
Жалоба сообщает наблюдение, но не задаёт условий, достаточных для повторения

Воспроизводимый дефект – дефект, для которого зафиксирован сценарий, надёжно приводящий к наблюдаемому проявлению. Воспроизводимость – первое звено цикла доказанного исправления.



Через 5 минут – да, через час – нет

9 / 39



Какого существенного условия не хватает в сценарии?

НЕДОСТАЮЩЕЕ ПРЕДУСЛОВИЕ

повтор выполняется до истечения срока действия ссылки

«Иногда» часто скрывает незаписанное существенное условие



Четыре поля воспроизводимого сценария

10 / 39

Воспроизводимый сценарий

ПРЕДУСЛОВИЯ

что должно быть истинно до начала: версия, роль, данные, существенные условия

ДЕЙСТВИЯ

что именно и в каком порядке выполняется – другой участник повторит без догадок

НАБЛЮДАЕМЫЙ РЕЗУЛЬТАТ

какой факт реально получен, без объяснения причины

ОЖИДАЕМЫЙ РЕЗУЛЬТАТ

что должно было произойти по требованию или безопасному поведению



Собираем сценарий одноразовой ссылки

11 / 39

Воспроизводимый сценарий

ПРЕДУСЛОВИЯ

версия с клиентской заплаткой; создана действующая ссылка; повтор – до истечения срока её действия

ДЕЙСТВИЯ

1. Первое обращение по ссылке успешно меняет учётные данные
2. То же значение ссылки отправляется повторно прямым запросом

НАБЛЮДАЕМЫЙ РЕЗУЛЬТАТ

вторая операция снова принимается

ОЖИДАЕМЫЙ РЕЗУЛЬТАТ

повтор отклоняется, учётные данные повторно не меняются



Один сценарий – две версии продукта

12 / 39

один и тот же сценарий



ИСХОДНАЯ ВЕРСИЯ

дефект воспроизводится: повтор принят



ИСПРАВЛЕННАЯ ВЕРСИЯ

нежелательный сценарий не проходит:
повтор отклонён

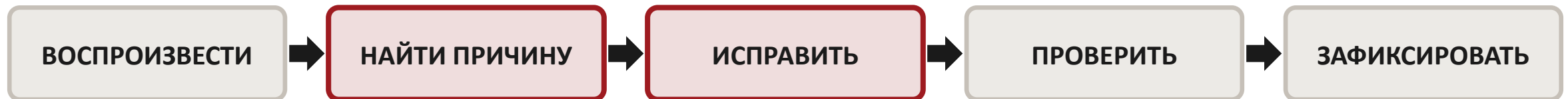
Проверка, которая была зелёной и до исправления,
сама по себе не доказывает это исправление



Секция 3

Симптом, причина и выбор изменения

Исправлять нужно механизм, а не место, где мы увидели последствия





Симптом, место проявления, причина

14 / 39

Симптом и причина

– различие наблюдаемого проявления дефекта и механизма, который его порождает. Исправление должно устранять причину, а не только маскировать симптом.

СИМПТОМ

повторная смена учётных данных той же ссылкой

МЕСТО ПРОЯВЛЕНИЯ

обработчик операции восстановления

ПРИЧИНА

?

**Место проявления помогает искать,
но ещё не объясняет механизм**



Три гипотезы: связываем с фактами

15 / 39

Г1

Проблема только в клиентском интерфейсе



УЖЕ ИЗВЕСТНО · ЭКРАН 5

Прямой повторный запрос проходит и без формы



СНЯТА

Г2

Сервер неправильно учитывает срок действия ссылки



УЖЕ ИЗВЕСТНО · ЭКРАН 9

Через час ссылка отклоняется: срок учитывается



**НЕ ОБЪЯСНЯЕТ ПОВТОР
В ПРЕДЕЛАХ СРОКА**

Г3

После успеха сервер по-прежнему считает ссылку допустимой



НОВОЕ НАБЛЮДЕНИЕ

После первого восстановления запись ссылки на сервере: «действительна»



**ПОДДЕРЖАНА:
МЕХАНИЗМ ЕЩЁ НЕ НАЗВАН**



Какая формулировка называет причину?

16 / 39

А

НАБЛЮДАЕМОЕ СОСТОЯНИЕ СИСТЕМЫ

«сервер и после первого применения продолжает считать использованную ссылку допустимой»

Б

ПРОЯВЛЕНИЕ

«повторный запрос с тем же значением снова принимается обработчиком восстановления»

В

МЕХАНИЗМ: НЕДОСТАЮЩИЙ ПЕРЕХОД СОСТОЯНИЯ

«после успешного восстановления сервер не переводит ссылку в состояние, исключающее повторное применение»

Г

МЕСТО ПРОЯВЛЕНИЯ

«дефект находится в обработке операции восстановления, который принимает повторный запрос»

**Хорошая причина объясняет наблюдение
и достаточно конкретна для выбора изменения**



Почему первая заплатка не помогла?

17 / 39



Временная ограничивающая мера может уменьшить число случайных повторов, но не является исправляющим изменением, пока причина сохраняется

**Клиентская заплатка изменила интерфейс,
но не установленный серверный механизм**



Что такое исправляющее изменение

18 / 39

Исправляющее изменение – обоснованное изменение требований, проектного решения, кода или конфигурации, которое устраняет причину дефекта безопасности либо надёжно разрывает путь его проявления. Само наличие изменения не доказывает исправление без результатов проверок изменённой версии.

Что может меняться

требования

проектное решение

код

конфигурация

ЧТО ЗНАЧИТ «НАДЁЖНО РАЗРЫВАЕТ ПУТЬ»

Нежелательный сценарий блокируется на том пути обработки, по которому он воспроизводился, – а не просто становится недоступным через один интерфейс



Два изменения – два разных результата

19 / 39

ИЗМЕНЕНИЕ 1 · КЛИЕНТ

Клиент скрывает форму после первого использования



СВЯЗЬ С ПРИЧИНОЙ

серверный механизм остаётся прежним:
прямой повтор проходит

ИЗМЕНЕНИЕ 2 · СЕРВЕР

После успешной операции сервер переводит ссылку в состояние «использована» и отклоняет последовательный повтор



СВЯЗЬ С ПРИЧИНОЙ

меняет установленный механизм: появляется недостающий переход состояния

**Изменение оценивается по тому,
меняет ли оно установленный механизм**



От причины – к области регрессии

20 / 39

ПРИЧИНА

После успешного
восстановления сервер не
переводит ссылку в
состояние, исключающее
повторное применение



ИЗМЕНЕНИЕ

Состояние «использована»
участвует в серверном
решении о допустимости
последовательного повтора



ОБЛАСТЬ ИЗМЕНЕНИЯ

Обработка восстановления;
жизненный цикл ссылки;
выпуск и истечение ссылки;
связанные пользовательские
сценарии

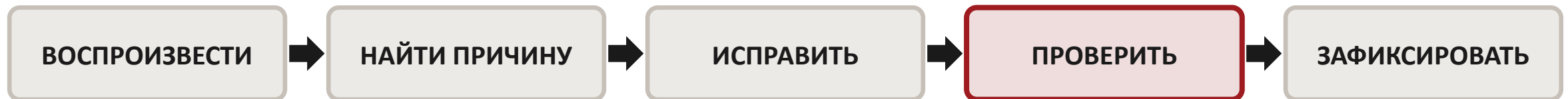
**Область изменения подсказывает
будущий регрессионный охват**



Секция 4

Три проверки – три вопроса

После изменения недостаточно проверить только исчезновение нежелательного сценария





Три вопроса после изменения

22 / 39

НЕГАТИВНАЯ ПРОВЕРКА

**Нежелательный
сценарий больше не
проходит?**

подтверждает
предусмотренную безопасную
реакцию на недопустимое
действие или ввод

ПОЗИТИВНАЯ ПРОВЕРКА

**Основная разрешённая
функция всё ещё
работает?**

подтверждает ожидаемое
поведение при допустимом
действии или вводе

РЕГРЕССИОННАЯ ПРОВЕРКА

**Ранее работавшее
затронутое поведение
не нарушено?**

выявляет нарушения ранее
обеспеченного поведения
после изменения

**Это три разные роли доказательства,
а не обязательные три тестовых файла**



Негативная проверка: ответ и состояние

23 / 39

Негативная проверка · псевдотест

1 Первое использование ссылки



восстановление
успешно

2 Повторить ту же ссылку



операция отклонена

3 Проверить учётные данные



не изменились

НЕДОСТАТОЧНАЯ ПРОВЕРКА

«Получили отказ 4xx – значит,
проверка пройдена»

ЧТО ОСТАЁТСЯ НЕИЗВЕСТНЫМ

изменились ли учётные данные
при втором запросе

**Негативная проверка смотрит на поведение продукта
и защищаемое состояние, а не только на код ответа**

«Негативная» не значит «тест должен упасть»: успех – предусмотренный безопасный отказ



Позитивная проверка: функция сохранена

24 / 39

Позитивная проверка · псевдотест

1 Выпустить новую ссылку



ссылка действует

2 Использовать её один раз



восстановление
успешно

3 Войти с новыми данными



вход выполнен

АНТИПРИМЕР «ИСПРАВЛЕНИЯ»

Запретить все восстановления:
исходный повтор исчезнет

ЧТО ПРИ ЭТОМ ПОТЕРЯНО

назначение функции: доступ не
восстановит никто

Позитивная проверка защищает
основную полезность продукта



Регрессионная: что ещё могло сломаться?

25 / 39

ОБЛАСТЬ ИЗМЕНЕНИЯ

обработка восстановления и жизненный цикл ссылки

Затронутые сценарии, которые работали раньше

Обычный вход после восстановления

вход с новыми учётными данными выполняется

Истечение срока ссылки

просроченная ссылка по-прежнему отклоняется

Выпуск новой ссылки после восстановления

новая ссылка выпускается и действует

**Регрессионный набор определяется областью изменения,
а не желанием «прогнать всё»**



Почему любых двух ролей недостаточно?

26 / 39

негативная + позитивная

без регрессионной



ОСТАЁТСЯ НЕИЗВЕСТНЫМ

смежный сценарий мог быть сломан

позитивная + регрессионная

без негативной



ОСТАЁТСЯ НЕИЗВЕСТНЫМ

неизвестно, исчез ли исходный дефект

негативная + регрессионная

без явного штатного сценария



ОСТАЁТСЯ НЕИЗВЕСТНЫМ

запрет подтверждён, основная полезная функция
– нет

**Роли разные, но один физический тест
может содержательно выполнять несколько ролей**



Регрессионная и повторная проверки

27 / 39

Повторная проверка – выполнение связанных с дефектом или свойством проверок на исправленной версии и после последующих изменений, способных затронуть полученный результат. Сравнимость требует сохранить существенные условия либо явно объяснить их изменение.

РЕГРЕССИОННАЯ – ЧТО ПРОВЕРЯЕМ

какое ранее работавшее поведение проверяем после изменения?

ПОВТОРНАЯ – КОГДА И НА ЧЁМ

когда и на какой версии снова выполняем связанные проверки?

исправление проверено
на версии 1.4



изменена смежная
обработка ответа



значимые проверки снова
выполнены на версии 1.5

Повторная проверка подтверждает уже сформулированные утверждения после изменения версии или условий



Зелёный запуск – ещё не свидетельство

28 / 39



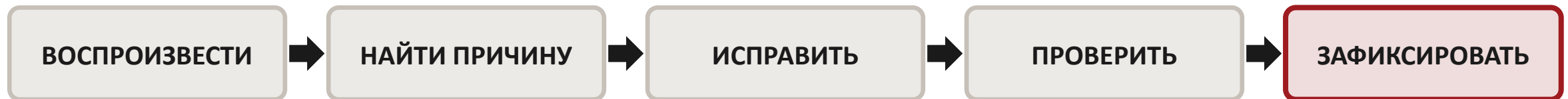
**Успешный набор подтверждает только охваченное поведение
в заданных условиях на указанной версии**



Секция 5

Цепочка доказанного исправления

Результат работы – не само изменение, а прослеживаемое доказательство





Цепочка доказанного исправления

30 / 39

Цепочка доказанного исправления

– прослеживаемая связь
воспроизводимой проблемы, её
причины, исправляющего изменения и
результатов проверки исправленной
версии.

ПО ЦЕПОЧКЕ МОЖНО НАЙТИ

изменение, проверки и фактические результаты

ДРУГОЙ ИНЖЕНЕР МОЖЕТ

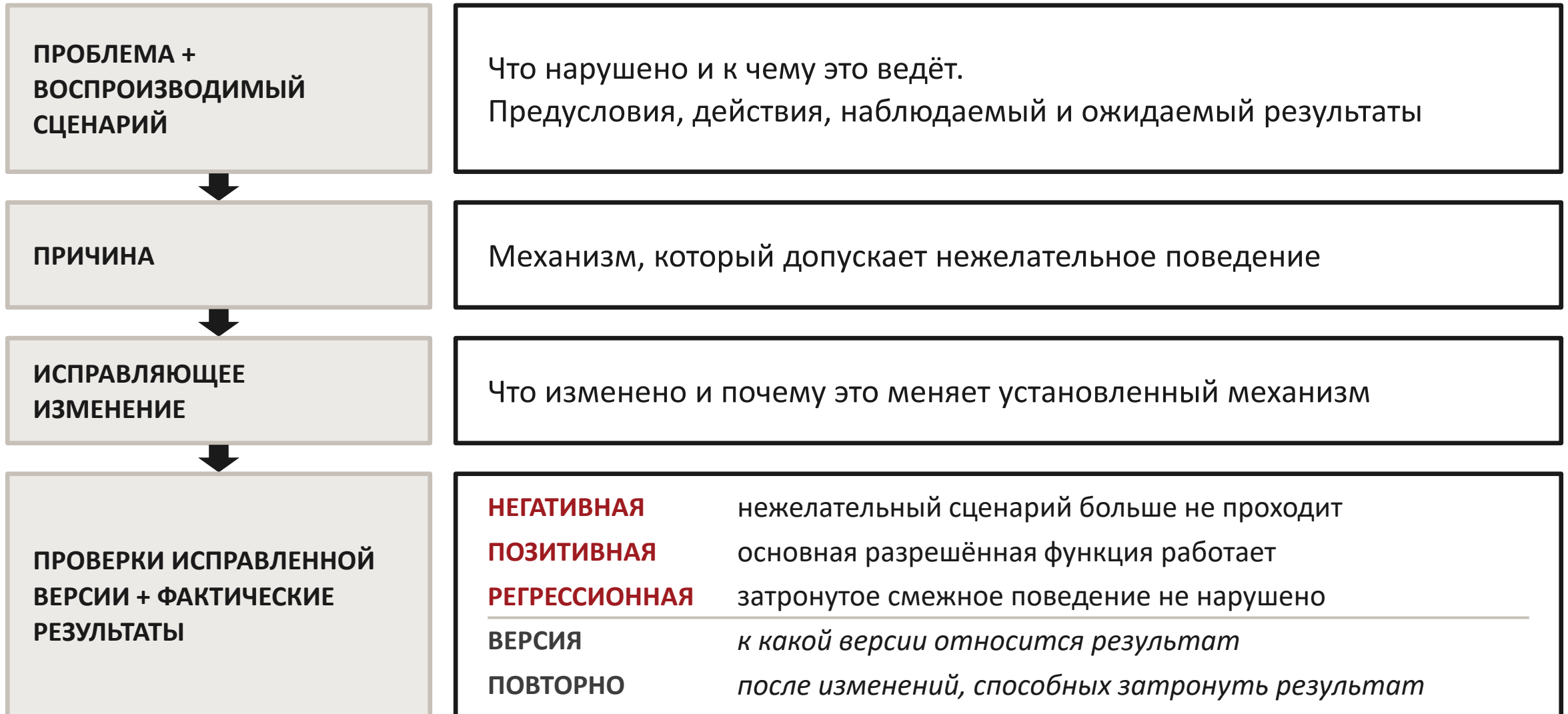
независимо восстановить логику вывода

**Цепочка – читаемая структура уже сделанной работы,
а не дополнительный большой отчёт**



Один скелет цепочки на всю лекцию

31 / 39





Цепочка указывает на артефакты

32 / 39

ПРОБЛЕМА +
ВОСПРОИЗВОДИМЫЙ
СЦЕНАРИЙ

DEF-... запись о дефекте: описание воспроизводимого сценария или автоматизированный тест

ПРИЧИНА

зафиксированная формулировка причины

ИСПРАВЛЯЮЩЕЕ
ИЗМЕНЕНИЕ

CHANGE-... идентификатор изменения в репозитории или принятая в проекте ссылка

ПРОВЕРКИ ИСПРАВЛЕННОЙ
ВЕРСИИ + ФАКТИЧЕСКИЕ
РЕЗУЛЬТАТЫ

ПРОВЕРКИ reset_link_reuse_rejected, reset_link_valid_works,
reset_link_expiry_preserved
РЕЗУЛЬТАТ сохранённый результат запуска и версия продукта
«Проверено» без результата и версии – разрыв цепочки



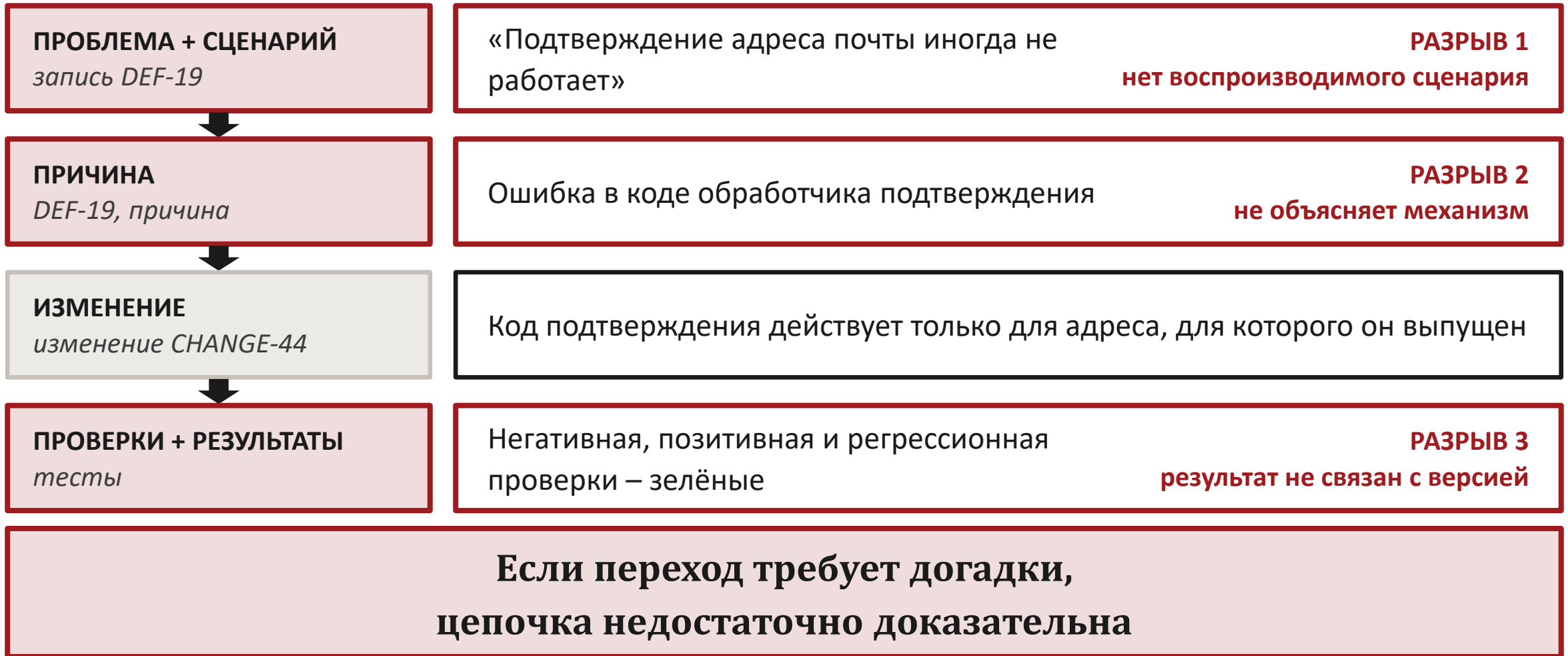
Одноразовая ссылка: полная цепочка





Найдите три разрыва в цепочке

34 / 39



Учебный пример: намеренно испорченная цепочка другого дефекта



Что эта цепочка не доказывает?

35 / 39

Подтверждено

- последовательный повтор использованной ссылки отклоняется
- в проверенных условиях, на версиях 1.4 и 1.5
- основной полезный сценарий сохранён

Не доказано этой цепочкой

- безопасность доставки ссылки
- качество случайного значения
- другие пути восстановления доступа
- поведение при одновременных запросах

**Доказанное исправление – сильное,
но ограниченное утверждение**



Перенесите метод на новую жалобу

36 / 39

НОВАЯ ЖАЛОБА

«После выпуска новой ссылки восстановления старая иногда остаётся работоспособной»

ТРЕБОВАНИЕ

Действовать должна только последняя выпущенная ссылка восстановления

1. Какие существенные предусловия нужно добавить в сценарий?
2. Как сформулировать негативную проверку для этого требования?

ПРЕДУСЛОВИЯ

старая ссылка не использована и не просрочена;
новая выпущена для той же учётной записи

НЕГАТИВНАЯ ПРОВЕРКА

после выпуска новой ссылки обращение по старой отклоняется, учётные данные не меняются

Причину пока не называем: сначала сценарий и проверка



Пять выводов лекции

37 / 39

- 1** работа с дефектом начинается с воспроизводимого сценария
- 2** причина – механизм, а не место проявления
- 3** исправляющее изменение связывается с установленной причиной
- 4** три роли проверок отвечают на разные вопросы; повторная проверка связывает вывод с версиями
- 5** результат – одна прослеживаемая цепочка с фактическими результатами и версией

РЕЗУЛЬТАТ 1

сценарий, симптом, причина:
экраны 8-16, перенос – 36

РЕЗУЛЬТАТ 2

изменение и проверки: экраны
17-28

РЕЗУЛЬТАТ 3

цепочка: экраны 30-34;
самостоятельно – семинар 06



Где этот метод понадобится дальше

38 / 39

Семинар 06

Впервые самостоятельно проходите полный цикл на подготовленном учебном объекте и предъявляете цепочку как результат работы

Лекция 06

Тот же цикл применяется к дефектам обработки данных

Лекция 07

Тот же цикл применяется к контролю доступа

Материал лекции 05 не входит в ДЗ-1; ДЗ-1 охватывает материал лекций 01-04

